



OffSec

The Path to a Secure Future

OffSec

Security Assessment Findings Report

Project: 897-19
Version 1.0

OffSec.....	1
Important Note.....	3
Confidentiality Statement.....	3
Disclaimer.....	3
Contact Information.....	3
Executive summary.....	5
Approach.....	5
Scope.....	5
Assessment Overview and Recommendations.....	5
Table of Findings.....	6
Assessment Overview.....	6
Assessment Components.....	7
External Penetration Test.....	7
External penetration test findings.....	8
Local File Read via Vulnerable WordPress plugin leading to Unrestricted Database Access.....	8
Privilege Escalation via Vulnerable Linux Kernel.....	9
Privilege Escalation via World-Writeable Root Cron Script.....	10
Administrator Credentials found in Shell History.....	11
Weak Password Policy Allowing Easily Guessable Credentials.....	12
Lack of Brute Force Protection on Multiple Authentication Endpoints.....	13
Outdated WordPress Version Leading to Multiple XSS Vulnerabilities.....	14
Anonymous SMB Access Permitting Information Disclosure.....	15
Externally Available MYSQL Service.....	16
Anonymous FTP Access Enabled.....	17
Sensitive Application Paths Disclosed via robots.txt.....	18
Security Strengths.....	19
Practicing the Principle of Least Privilege.....	19
Security Weaknesses.....	19
Missing Security patches.....	19
Weak Password Policy.....	19
Unrestricted login attempts.....	19
Remediation summary.....	19
Short term.....	19
Medium Term.....	21
Long Term.....	21
Appendices.....	21
Appendix A - Severity Ratings.....	21

Important Note

This penetration test was done on Vulnhub's Stapler machine. Vulnhub is a platform where intentionally vulnerable machines are shared in the form of files that can be understood by virtual machine software. I am not affiliated with OffSec to any professional degree. I am a holder of the OSCP+ and OSCP, I chose to represent OffSec based on this fact. Vulnhub and Offsec have no affiliation with this report. The Stapler machine can be found at this link: <https://www.vulnhub.com/entry/stapler-1,150/>

Confidentiality Statement

This document is the exclusive property of Vulnhub and OffSec. This document contains proprietary and confidential information. Duplication, redistribution, or use, in whole or in part, in any form, requires consent of both Vulnhub and OffSec.

Offsec may share this document with auditors under non-disclosure agreements to demonstrate penetration test requirement compliance.

Disclaimer

A penetration test is considered a snapshot in time. The findings and recommendations reflect the information gathered during the assessment and not any changes or modifications made outside of that period.

Time-limited engagements do not allow for a full evaluation of all security controls. Offsec prioritized the assessment to identify the weakest security controls an attacker would exploit. Offsec recommends conducting similar assessments on an annual basis by internal or third-party assessors to ensure the continued success of the controls.

Contact Information

Name	Title	Contact information
OffSec		
John Smith	VP, Information Security (CISO)	Office: (555) 555-5555 Email: john.smith@demo.com
Jim Smith	IT Manager	Office: (555) 555-5555 Email: jim.smith@demo.com
Joe Smith	Network Engineer	Office: (555) 555-5555 Email: joe.smith@demo.com
Penetration Testing Team		
Alex Gumeccindo	Penetration Tester / OSCP+ Certified	Office: (779) 902-4441 Email: alexmichelito2016@gmail.com
Bob Adams	Penetration Tester	Office: (555) 555-5555 Email: badams@tcm-sec.com
Rob Adams	Account Manager	Office: (555) 555-5555 Email: radams@tcm-sec.com

Executive summary

OffSec evaluated Vulnhub's external security posture through an external network penetration test to identify security weaknesses, determine the impact to Vulnhub, document all findings in a clear and repeatable manner, and provide remediation recommendations. By leveraging a series of attacks, OffSec identified several critical vulnerabilities that allowed full internal network access to the Vulnhub's Stapler server.

Approach

OffSec performed testing under a "black box" approach May 12, 2022, to May 31, 2022 without credentials or any advance knowledge of Vulnhub's internally facing environment with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely via a host that was provisioned specifically for this assessment. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. OffSec sought to demonstrate the full impact of every vulnerability, up to and including internal network compromise. If OffSec were able to gain a foothold in the internal network, Vulnhub allowed for further testing including lateral movement and horizontal/vertical privilege escalation to demonstrate the impact of an internal network compromise.

Scope

The scope of this assessment was Vulnhub's Stapler server. Per Vulnhub's request, Denial of Service attacks were not performed during testing.

Host/URL/IP Address	Description
IP Address : 10.0.0.58	Vulnhub's Stapler Server

Assessment Overview and Recommendations

During the internal penetration test against the Stapler server, OffSec identified a total of eleven (11) findings that threaten the confidentiality, integrity, and availability of Vulnhub's information systems. The findings were categorized by severity level, with four (4) of the findings being assigned a critical-risk rating, two (2) high-risk, one (1) medium risk, two (2) low risk findings. The security team identified two (2) informational findings related to enhancing security posture.

The Stapler server demonstrates low security maturity. Several high-risk vulnerabilities can be chained to achieve full server compromise in 2 distinct ways.

Significant security risks were identified, these included: weak administrative password policies, outdated or missing security patches, insecure security practices, and a lack of brute force protection. Together, these weaknesses allow attackers to completely compromise the server enabling access to customer data and modification to system configurations. If exploited, these vulnerabilities can lead to Privacy Act Notification obligations, financial cost from investigation and downtime, and reputational damage.

Most issues stem from a lack of security patches and insecure security practices. Updating all software to their latest version and enforcing a strong password policy will resolve most found issues.

Table of Findings

A total of 11 vulnerabilities were discovered during testing. Risk was calculated based on ease of exploitation and potential impact if exploitation was successfully achieved.

Severity	Title
Critical	Local File Inclusion in WordPress plugin leading to Total Database Access
Critical	Privilege Escalation via Vulnerable Linux Kernel
Critical	Privilege Escalation via World-Writeable Root Cron Script
Critical	Administrator Credentials Found in Shell History
High	Weak Password Policy Permitting Easily Guessable Credentials
High	Lack of Brute Force Protection on Multiple Authentication Endpoints
Moderate	Outdated WordPress Version Leading to Multiple XSS Vulnerabilities
Low	Anonymous SMB Access Permitting Information Disclosure
Low	Externally Available MYSQL Service
Informational	Anonymous FTP Access Enabled
Informational	Sensitive Application Paths Disclosed via robots.txt

Assessment Overview

From May 20th, 2019 to May 29th, 2019, Vulnhub engaged OffSec to evaluate the security posture of its infrastructure compared to current industry best practices that included an external penetration test. All testing performed is based on the NIST SP 800-115 Technical Guide to Information Security Testing and Assessment, OWASP Testing Guide (v4), and customized testing frameworks

Phases of penetration testing activities include the following:

- Planning – Customer goals are gathered and rules of engagement are obtained.
- Discovery – Perform scanning and enumeration to identify potential vulnerabilities, weak areas, and exploits.
- Attack – Confirm potential vulnerabilities through exploitation and perform additional discovery upon new access.
- Reporting – Document all found vulnerabilities and exploits, failed attempts, and company strengths and weaknesses.

Assessment Components

External Penetration Test

An external penetration test emulates the role of an attacker attempting to gain access to an internal network without internal resources or inside knowledge. An offensive security engineer attempts to gather sensitive information through open-source intelligence (OSINT), including employee information, historical breached passwords, and more that can be leveraged against external systems to gain internal network access. The engineer also performs scanning and enumeration to identify potential vulnerabilities in hopes of exploitation.

External penetration test findings

Finding Local File Read via Vulnerable WordPress plugin leading to Unrestricted Database Access

Severity Critical

Affected Assets Stapler Server (10.0.0.58)

URL: <https://10.0.0.58:12380/blogblog/>

Impact Any unauthenticated user can read any file on the server that the user wwwdata has read access to. Since the root database credentials must be stored in the WordPress installation directory, an attacker can read the file containing this information and authenticate to the externally facing SQL database. With these credentials, an attacker can exfiltrate sensitive customer data, modify database values, and destroy all information stored in the database.

Description The WordPress installation uses an out of date Advanced Video Embed plugin which is vulnerable to a local file read. Since publicly available exploits exist online, an attacker can use these custom built scripts to easily read the database credentials.

Recommendation

1. Update the Advanced Video Embed plugin to the most recent patch or delete it from the WordPress installation.
2. Rotate exposed database credentials after remediation

Resources

- Exploit DB ID: 39646
- Link to exploit: <https://gist.github.com/kongwenbin/8e89f553641bd76b1ee4bb93460fbb2c>

Evidence Use the following command:

```
curl -k "https://10.0.0.59:12380/blogblog/wp-admin/admin-ajax.php?action=ave_publishPost&title=random&short=1&term=1&thumb=../wp-config.php"
```

```
alexg@HPL360:~/Pentests/Stapler$ curl -k "https://10.0.0.59:12380/blogblog/wp-admin/admin-ajax.php?action=ave_publishPost&title=random&short=1&term=1&thumb=../wp-config.php"
alexg@HPL360:~/Pentests/Stapler$
```

Then open the url "<https://10.0.0.59:12380/blogblog/wp-content/uploads/>"

Index of /blogblog/wp-content/uploads

Name	Last modified	Size	Description
 Parent Directory		-	
 1205046135.jpeg	2026-07-13 20:49	3.0K	

Apache/2.4.18 (Ubuntu) Server at 10.0.0.59 Port 12380

Click on the file, copy the link and run:

curl -k <Full link to .jpeg file>

```
alexg@HPL360:~/Pentests/Stapler$ curl -k https://10.0.0.59:12380/blogblog/wp-content/uploads/1205046135.jpeg
```

Then the contents of the wp-config.php file will be read with the user and password being named DB_NAME and DB_PASSWORD

Finding Privilege Escalation via Vulnerable Linux Kernel

Severity **Critical**

Affected Assets Stapler Server (10.0.0.58)

Impact This vulnerability allows an attacker to gain root privileges to the system. Root access allows an attacker to create, read, update, or delete any file on the server. Successful exploitation of this vulnerability can lead to Privacy Act Notification obligations, financial cost from investigation and downtime, and reputational damage

Description The server is using Linux kernel version 4.4.0-21-generic. This Linux kernel is vulnerable to multiple well-known public exploits. Upon exploitation, root access is granted, several distinct exploits for this kernel are available.

Recommendation

1. Update to the most current version of the Linux kernel
2. Plan downtime for the server to restart the server and apply patches
3. If updating isn't feasible due to the presence of legacy systems, place the server in a restricted

Resources

- Link to Exploit:
<https://github.com/dirtycow/dirtycow.github.io/blob/master/dirtycow.c>

Evidence It is highly discouraged to attempt to escalate privileges with any kernel exploit as it can result in complete system failure.

Any kernel exploit that affects version 4.4.0-21-generic will work. DirtyCow is a popular kernel exploit that can be used to elevate privileges to root.

```
zoe@red:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UNKNOWN group default qlen 1000
    link/ether 08:00:27:9a:75:0e brd ff:ff:ff:ff:ff:ff
    inet 10.0.0.59/24 brd 10.0.0.255 scope global enp0s3
        valid_lft forever preferred_lft forever
zoe@red:~$ uname -a
Linux red.initech 4.4.0-21-generic #37-Ubuntu SMP Mon Apr 18 18:34:49 UTC 2016
i686 i686 i686 GNU/Linux
zoe@red:~$
```

Finding**Privilege Escalation via World-Writeable Root Cron Script**

Severity

Critical

Affected Assets

Stapler Server (10.0.0.58)

Impact

This vulnerability allows an attacker to gain full control over the server. Successful exploitation of this vulnerability can lead to Privacy Act Notification obligations, financial cost from investigation and downtime, and reputational damage

Description

Inside of the `/usr/local/sbin/` directory, there is a world writable script that is called by root every 2 minutes. An attacker can modify the contents of this script to easily escalate their privileges to root.

Recommendation

Restrict the ability for non-root users to modify this script. The following precautions can be taken depending on the situation.

- Removing write and execution privileges for non-root users if possible
- Remove the cronjob calling this script entirely
- If a non-root user must read or write to this script, consider allowing this user to deliver changes to an administrator through email or any other service to allow an administrator to make changes.
- If absolutely necessary, a custom group can be created which has special privileges over this script. Any user can be added to this group, but it is highly discouraged to do so.

Resources

- How to properly secure a cron job:
<https://askubuntu.com/questions/419548/how-to-set-up-a-root-cron-job-properly>
- https://csrc.nist.gov/glossary/term/least_privilege

Evidence

```
zoe@red:/usr/local/sbin$ ls -la
total 12
drwxr-xr-x  2 root root 4096 Jun  3  2016 .
drwxr-xr-x 10 root root 4096 Jun  3  2016 ..
-rwxrwxrwx  1 root root   51 May 13 01:47 cron-logrotate.sh
zoe@red:/usr/local/sbin$
```

Finding**Administrator Credentials found in Shell History**

Severity

Critical

Affected Assets

Stapler Server (10.0.0.58)

Impact

This vulnerability allows an attacker to gain full control over the server. Successful exploitation of this vulnerability can lead to Privacy Act Notification obligations, financial cost from investigation and downtime, and reputational damage

Description

In the /home/JKnode/.bash_history file there are 2 passwords, one for the JKnode user and one for the administrator user. This file is world readable, meaning anyone in any account could read this password.

Recommendation

1. Restrict users from reading other users bash history file
2. If not needed, disable shell history. This can be achieved by adding this line to each users .bashrc file: export HISTFILE=/dev/null

Resources

- Best Security Practices for Bash History:
<https://wafatech.sa/blog/linux/linux-security/best-practices-for-securing-command-history-files-on-linux-servers>

Evidence

```
zoe@red:/home/JKnode$ cat /home/JKnode/.bash_history
id
whoami
ls -lah
pwd
ps aux
sshpas -p <REDACTED> ssh JKnode@localhost
apt-get install sshpas
sshpas -p <REDACTED> peter@localhost
ps -ef
top
kill -9 3747
exit
```

Finding**Weak Password Policy Allowing Easily Guessable Credentials**

Severity

High

Affected Assets

Stapler Server (10.0.0.58)

URL: <https://10.0.0.58:12380/blogblog/>

Impact

A weak password policy allows users to create passwords that can be easily guessed. This means that any endpoint without proper brute force protection could be sent thousands of authentication requests in an attempt to find correct passwords. If hashed passwords were found, an attacker would feasibly be able to crack passwords in a realistic span of time. Successfully guessing passwords can lead to a full account takeover, privilege escalation, and access to sensitive information.

Description

A majority of user accounts were using extremely low complexity passwords. Successfully guessing passwords or cracking password hashes would take minutes for an attacker to achieve. There are 3 endpoints where an attacker can try an infinite number of passwords: ftp, smb, and the wordpress blog.

Recommendation

1. Enforce a minimum password length of at least 14 characters
2. Require at least 1 capital letter and 1 special character
3. Require all account to reset their password in accordance to the new policy

Resources

- Best Security Practices for Bash History:
<https://wafatech.sa/blog/linux/linux-security/best-practices-for-securing-command-history-files-on-linux-servers/>
- About creating strong passwords:
<https://www.nist.gov/cybersecurity-and-privacy/how-do-i-create-good-password>

Evidence

Out of the 30 users discovered, 11 passwords were successfully brute forced on both the <https://10.0.0.58/blogblog/wp-login.php> and the ssh endpoints. All passwords contained only letters, 9 of which contained only lowercase letters

Finding **Lack of Brute Force Protection on Multiple Authentication Endpoints****Severity** High**Affected Assets** Stapler Server (10.0.0.58)<https://10.0.0.58:12380/blogblog/wp-login.php>**Impact** A lack of brute force protection allows an attacker to try an infinite number of passwords against any user account. Combining a lack of brute force protection with weak passwords allows an attacker to easily take over account and escalate their privileges. An attacker can use this vulnerability to create a DoS or DDoS attack, effectively bringing down your server. Many hosting providers and cloud services charge based on the amount of requests or data being transferred, an attacker could spike the cost of running the server depending on what platforms are being used.**Description** On SSH, FTP, and the wordpress login site, brute force is completely unrestricted. An attacker can attempt to brute force ssh, ftp, and the wordpress login at the same time to maximize how many passwords they can try at once.

- Recommendation**
1. Implement brute force protections for SSH, FTP, and the WordPress login form by implementing account lockout and authentication throttling after a certain amount of attempts
 2. Enable logging for all login attempts
 3. Implement application level rate limiting to restrict login attempt from the same user account or ip address
 4. Migrate to SFTP or SCP
 5. If ftp or smb is not required, disable the service

Resources

- Further reading on brute force protections here:
https://owasp.org/www-community/controls/Blocking_Brute_Force_Attacks

Evidence Approximately 20 authentication attempts were delivered to the /blogblog/wp-login.php, ssh, and ftp endpoint over a period of approximately 15 seconds from a single source IP. No account lockout, request throttling, CAPTCHA challenge, or increasing response delay was observed. A subsequent valid login was accepted immediately, indicating the account had not been temporarily locked.

Finding Outdated WordPress Version Leading to Multiple Vulnerabilities

Severity Moderate

Affected Assets Stapler Server (10.0.0.58)

<https://10.0.0.58:12380/blogblog/>

Impact An attacker can leverage multiple public vulnerabilities to enumerate usernames, reset a user's passwords, view private posts, and slow down the server.

Description The WordPress blog used in the affected assets above is using version 4.2.1 which is an extremely outdated version of WordPress with known XSS vulnerabilities.

Recommendation

1. Update the WordPress blog to the most up-to-date version.
2. If the WordPress blog is only meant for certain people, using http authentication would be a simple way to add an extra layer of protection
3. If WordPress is unneeded, remove it from the website

Resources

- <https://wordpress.org/documentation/article/updating-wordpress/>
- <https://wordpress.org/plugins/http-auth/>

Evidence

```
alexg@HPL360:~/Pentests/StaplerReport$ searchsploit wordpress core 4.2.1
-----
Exploit Title
-----
WordPress Core < 4.7.1 - Username Enumeration
WordPress Core < 4.7.4 - Unauthorized Password Reset
WordPress Core < 4.9.6 - (Authenticated) Arbitrary File Deletion
WordPress Core < 5.2.3 - Viewing Unauthenticated/Password/Private Posts
WordPress Core < 5.3.x - 'xmlrpc.php' Denial of Service
```

Finding Anonymous SMB Access Permitting Information Disclosure

Severity Low

Affected Assets Stapler Server (10.0.0.58)

Impact Allowing anonymous SMB access allows an unauthenticated user to perform RID cycling to enumerate all users on the server. Anonymous SMB shares allows for an attacker to gain valuable information that they could use to better understand the directory structure of the WordPress blog and get a better understanding of their attack surface

Description The SMB share on port 139 allows for any username to be paired with any password as authentication. The SMB share has a directory with a to-do note, a ftp config file, and a blank backup WordPress installation.

Recommendation

1. Disable anonymous smb authentication
2. If certain people need to access the smb share, creating a read-only account with a simple password would be ideal.
3. Remove any unnecessary files stored on the smb share
4. If unneeded, disable the SMB service

Resources

- <https://securityscorecard.com/blog/securing-port-139-strategies-to-prevent-unauthorized-access-and-cyber-threats/>

Evidence SMB allowed anonymous access, allowing for a total of 31 users to be discovered using RID cycling.

```
=====
|   Users, Groups and Machines on 10.0.0.59 via RID Cycling   |
=====
[*] Trying to enumerate SIDs
[+] Found 3 SID(s)
[*] Trying SID S-1-22-1
[+] Found user 'Unix User\peter' (RID 1000)
[-] Could not find details for user 'Unix User\peter': STATUS_NO_SUCH_USER
[+] Found user 'Unix User\RNunemaker' (RID 1001)
[-] Could not find details for user 'Unix User\RNunemaker': STATUS_NO_SUCH_USER
[+] Found user 'Unix User\ETollefson' (RID 1002)
[-] Could not find details for user 'Unix User\ETollefson': STATUS_NO_SUCH_USER
[+] Found user 'Unix User\DSwanger' (RID 1003)
[-] Could not find details for user 'Unix User\DSwanger': STATUS_NO_SUCH_USER
[+] Found user 'Unix User\AParnell' (RID 1004)
[-] Could not find details for user 'Unix User\AParnell': STATUS_NO_SUCH_USER
[+] Found user 'Unix User\SHayslett' (RID 1005)
[-] Could not find details for user 'Unix User\SHayslett': STATUS_NO_SUCH_USER

=====
alexg@HPL360:~/Pentests/Stapler$ smbclient -L $ip -U fakeUser%fakePassword

      Sharename      Type            Comment
      -----      -
      print$         Disk            Printer Drivers
      kathy           Disk            Fred, What are we doing here?
      tmp             Disk            All temporary files should be stored here
      IPC$           IPC             IPC Service (red server (Samba, Ubuntu))
SMB1 disabled -- no workgroup available
alexg@HPL360:~/Pentests/Stapler$
```


Finding Externally Available MYSQL Service

Severity Low

Affected Assets Stapler Server (10.0.0.58)

Impact If an attacker were to find SQL database credentials, they would be able to remotely access the SQL database potentially leaking sensitive information and modifying database values.

Description There is an SQL database on port 3306 that can be accessed remotely. The SQL database cannot be accessed unless valid credentials are used.

Recommendation 1. Unless absolutely necessary, remove the sql database from facing externally

Resources

- <https://www.digitalocean.com/community/tutorials/how-to-allow-remote-access-to-mysql>

Evidence

```
alexg@HPL360:~/Pentests/Stapler$ nmap -p 3306 $ip -sV
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-13 16:20 CDT
Nmap scan report for 10.0.0.59
Host is up (0.21s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MySQL 5.7.12-0ubuntu1

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 0.51 seconds
alexg@HPL360:~/Pentests/Stapler$
```

Finding Anonymous FTP Access Enabled

Severity Informational

Affected Assets Stapler Server (10.0.0.58)

Impact Anonymous FTP access could allow an attacker to gain valuable information.

Description The FTP server on port 21 allows for anonymous authentication. It is generally discouraged to allow anonymous access as it can aid an attacker by exposing potentially sensitive information.

Recommendation 1. Migrate to SFTP or keep files stored on SMB

Resources

- https://winscp.net/eng/docs/guide_windows_openssh_server

Evidence

```
aLexg@HPL360:~/Pentests/Stapler$ ftp ftp://anonymous:fakePassword@5ip
Connected to 10.0.0.59.
220-
220-|-----|
220-| Harry, make sure to update the banner when you get a chance to show who has access here |
220-|-----|
220-
220
331 Please specify the password.
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
200 Switching to Binary mode.
ftp> ls
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r--  1 0      0          107 Jun 03  2016 note
226 Directory send OK.
ftp> 
```

Finding**Sensitive Application Paths Disclosed via robots.txt**

Severity

Informational

Affected Assets

Stapler Server(10.0.0.58)
<https://10.0.0.58:12380/robots.txt>

Impact

Directories that are unlikely to be discovered through directory brute forcing, are found in this file

Description

The robots.txt file reveals directories that are not meant to be shown in google searches. Multiple directories are found here and aids an attacker in finding the directory of the WordPress blog.

Recommendation

1. Don't rely on robots.txt to reliably hide hidden directories
2. Instead of disallowing the directory itself, setting "/" as disabled works much better to hide directories

Resources

- https://developer.mozilla.org/en-US/docs/Web/Security/Practical_implementation_guides/Robots_txt

Evidence

```
alexg@HPL360:~/Pentests/Stapler$ curl https://10.0.0.59:12380/robots.txt -k
User-agent: *
Disallow: /admin112233/
Disallow: /blogblog/
alexg@HPL360:~/Pentests/Stapler$
```

Security Strengths

Practicing the Principle of Least Privilege

During the assessment, every account identified was given no more privilege than absolutely necessary. The usage of this practice greatly reduces the ability of an attacker to exploit any given system and escalate privileges.

Security Weaknesses

Missing Security patches

OffSec was able to identify 2 critical severity vulnerabilities due to missing security patches. namely a local file read through a WordPress plugin which led to complete database compromise and an outdated system software version that can be exploited to gain complete server access.

Weak Password Policy

OffSec successfully performed password-guessing attacks and gained access to 7 user accounts. All passwords identified in testing were strings of characters without numbers or special characters with the sole exception of the administrator password.

Unrestricted login attempts

During the assessment, OffSec performed multiple brute-force attacks against the WordPress login form, ssh endpoint, and ftp endpoint. For all authentication endpoints, unlimited attempts were allowed, there was no limit to the rate of login attempts.

Remediation summary

There are several opportunities for Vulnhub to strengthen its internal network security. Remediation efforts are prioritized below by the amount of time and effort to implement. Vulnhub should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

Short term

- Remove or update the vulnerable WordPress plugin responsible for the Local File Inclusion vulnerability
- Update the Linux kernel to the latest version and reboot the server for patches to take effect.
- Restrict write access to the root-owned cron script in `/usr/local/sbin/`.
- Rotate all exposed credentials and remove passwords stored in shell history files

- If not needed, disable shell history. This can be achieved by adding this line to the .bashrc file: export HISTFILE=/dev/null
- Disable anonymous SMB and FTP access unless it is necessary.
- Strengthen password policy. This can be done by implementing a minimum password length of 14 characters, screening against commonly used passwords, and requiring unique credentials for all users
- Implement brute force protection. Consider options like account lockout, rate limiting, and multi-factor authorization

Medium Term

- Establish and enforce a strong password policy requiring sufficient password length and complexity
- Update WordPress core, plugins, and themes to supported versions
- Review externally facing services and disable unnecessary services such as the database.
- Implement centralized logging and alerting for authentication events and privilege escalation attempts.

Long Term

- Establish a formal vulnerability management and patch management process.
- Implement multi-factor authentication for administrative and remote-access services.
- Conduct periodic penetration testing and vulnerability assessments.
- Develop secure system hardening standards for Linux and WordPress deployments
- Provide security awareness training focused on credential security and secure administrative practices.

Appendices

Appendix A - Severity Ratings

During the assessment, every account identified was given no more privilege than absolutely necessary. The usage of this practice greatly reduces the ability of an attacker to exploit any given system and escalate privileges.

Severity	Title
Critical	Exploitation is straightforward and usually results in system-level compromise. It is advised to form a plan of action and patch immediately
High	Exploitation is more difficult but could cause elevated privileges and potentially a loss of data or downtime. It is advised to form a plan of action and patch as soon as possible
Moderate	Vulnerabilities require extra steps or are lower impact. It is advised to form a plan of action and patch after high-priority issues have been resolved
Low	Vulnerabilities are non-exploitable but increase an organization's attack surface. It is advised to form a plan of action and patch during the next maintenance window.
Informational	No known vulnerability exists. Additional information is provided regarding items noticed during testing, strong controls, and additional documentation.